BOARD RISK COMMITTEE

Chief Risk Officer's Report

Meeting	Board Risk Committee	**Reporting period**	November 2026
Presented by	Chief Risk Officer (SMF4)	**Position as at**	5 Nov 2026
Purpose	For decision and noting	**Classification**	Confidential

Decisions requested and matters to note

1. Decide: the path to green for Exploit attempt on unpatched perimeter vulnerability, target 30 Nov 2026.
2. Decide: the path to green for AML Alert Disposition SLA Control, target 29 Jan 2027.
3. Note: KYC refresh backlog on high-risk relationships is past its 31 Oct 2026 target. Delay accepted by Board Risk Committee, 12 Oct 2026.
4. Review: the plan for Mean time to patch critical vulnerabilities was sent back on 12 Oct 2026.

Chief Risk Officer's overview

FIRM POSTURE	OUT OF TOLERANCE	CRITICAL CONTROLS	INCIDENTS
RED	2 metrics	94%	1 Sev-1 · 2 Sev-2
Same as Oct · Cyber & Information Security	Worst: Critical vulnerabilities open	Down from 96%	Exploit attempt on unpatched perimeter vulnerability

1. Firm risk posture is RED, unchanged from Oct, driven by Cyber & Information Security. [RAM-CY-01]
2. 2 risk appetite metrics are out of tolerance: Critical vulnerabilities open (3 open vs tolerance 2 open); Mean time to patch critical vulnerabilities (432 hours vs tolerance 336 hours). [RAM-CY-01, RAM-CY-02]
3. Critical controls are 94% effective, down from 96%; the lowest is Fraud & Financial Crime at 85%. [AML-C002]
4. AML-C002 retested 3 Nov 2026: not effective. Disposition control under capacity stress. [AML-C002]
5. 1 Sev-1 incident and 2 Sev-2 incidents are open or new this month, led by: Exploit attempt on unpatched perimeter vulnerability. [INC-2026-041, INC-2026-040]
6. On the horizon: Google Cloud London region outage disrupts banks (Reuters, 21 Oct 2026). [HZ-IND-001]

Chief Risk Officer (SMF4)

1. Risk profile

The risk profile against Board-approved risk appetite is RED (also RED in Oct). Rule: Any Level-1 risk red makes the firm red. Driven by Cyber & Information Security.

Principal risk	Rating	Since last review	RAMs red / amber	Critical controls	Sev-1/2	Basis of rating and path to green
Cyber & Information Security	RED	Unchanged	2 / 1	90%	2	Red because 2 RAMs out of tolerance · 1 critical control failed · 1 Sev-1 incident Path to green: Jan 2027 · Head of Information Security
Fraud & Financial Crime	AMBER	Unchanged	0 / 5	85%	1	Amber because 5 RAMs above limit · critical controls 85% effective · 1 Sev-2 incident Path to green: Apr 2027 · Head of Financial Crime Compliance
Climate Risk	GREEN	Unchanged	0 / 0	100%	0	Within appetite
Conduct & Reputation	GREEN	Unchanged	0 / 0	100%	0	Within appetite
Credit Risk	GREEN	Improved	0 / 0	100%	0	Within appetite
Liquidity & Funding	GREEN	Unchanged	0 / 0	100%	0	Within appetite
Market Risk	GREEN	Unchanged	0 / 0	100%	0	Within appetite
Operational Resilience	GREEN	Unchanged	0 / 0	100%	0	Within appetite
Regulatory	GREEN	Unchanged	0 / 0	100%	0	Within appetite

Top material items

Item	Position	Cause and proposed action	Owner	Target
Critical vulnerabilities open Cyber & Information Security	3 open vs tolerance 2 open	Vendor patch for the perimeter security stack needs phased rollout across production. Action: Complete phased rollout across the production estate	Head of Information Security	13 Nov 2026
Mean time to patch critical vulnerabilities Cyber & Information Security	432 hours vs tolerance 336 hours	Patch windows are shared with core-banking release freezes. Action: Create an emergency patch window outside the release calendar	Head of Information Security	29 Jan 2027
AML Alert Disposition SLA Control Fraud & Financial Crime	Test result: not effective, 3 Nov 2026	Disposition control under capacity stress. Action: Add L2 investigator capacity	Head of Financial Crime Compliance	29 Jan 2027
Critical Vulnerability Patching Cyber & Information Security	Test result: not effective, 3 Nov 2026	Critical vulnerabilities open beyond the patching standard. Action: Complete the phased patch rollout	Head of Information Security	30 Nov 2026
Exploit attempt on unpatched perimeter vulnerability Cyber & Information Security	Sev-1 · open	Attempted exploit of a perimeter vulnerability still awaiting its patch. Action: Apply compensating firewall rules	Head of Information Security	30 Nov 2026

What changed from last review

1. New Sev-1: Exploit attempt on unpatched perimeter vulnerability [INC-2026-041]
2. Closure pack signed; 3 critical vulnerabilities still open [EVID-CYBER-CLOSURE-2026-07]
3. AML-C002 retested 3 Nov 2026: not effective. Disposition control under capacity stress. [EV-CT-AML-C002-2026-11]
4. New Sev-2: Cross-border structuring alerts past disposition SLA [INC-2026-040]
5. Credit Risk AMBER → GREEN: Portfolio delinquency 2.3% vs limit 2.5% [RAM-CR-01]

2. Risk appetite position

Of 50 risk appetite metrics, 42 are green, 6 amber and 2 red. Metrics outside appetite follow, with the proposed action for each. The full register is on the Risk Appetite tab.

Metric	Status	Value	Limit	Tolerance	Cause and proposed action	Path to green	Second line and committee
Critical vulnerabilities open Head of Information Security	RED	**3 open**	0	2	Vendor patch for the perimeter security stack needs phased rollout across production. Action: Complete phased rollout across the production estate	13 Nov 2026	Accepted Accepted by Board Risk Committee, 12 Oct 2026
Mean time to patch critical vulnerabilities Head of Information Security	RED	**432 hours**	168	336	Patch windows are shared with core-banking release freezes. Action: Create an emergency patch window outside the release calendar	29 Jan 2027	Challenged Sent back by Board Risk Committee, 12 Oct 2026
Privileged access reviews overdue Head of Information Security	AMBER	**2 reviews**	0	5	Two quarterly reviews slipped during the vulnerability response. Action: Complete both overdue privileged access reviews	30 Nov 2026	Pending Decision pending at Executive Risk Committee
AML alert backlog above SLA Head of Financial Crime Compliance	AMBER	**6.4%**	5%	8%	Alert volumes exceed L2 investigator capacity. Action: Add L2 investigator capacity	26 Feb 2027	Accepted Bring forward, decided by Executive Risk Committee, 20 Oct 2026
EDD completed on time Head of Financial Crime Compliance	AMBER	**93%**	98%	90%	EDD analysts were redeployed to the KYC refresh backlog. Action: Ring-fence EDD analyst capacity	29 Jan 2027	Accepted Accepted by Executive Risk Committee, 20 Oct 2026
High-risk reviews overdue Head of Financial Crime Compliance	AMBER	**17%**	5%	20%	Linked to the KYC refresh backlog on high-risk relationships. Action: Prioritise overdue high-risk reviews within the refresh team	30 Apr 2027	Accepted Accepted by Board Risk Committee, 12 Oct 2026
KYC refresh backlog on high-risk relationships Head of Financial Crime Compliance	AMBER	**4,380 cases**	1,000	5,000	Periodic refreshes were deferred during the core-banking migration. Action: Stand up a dedicated refresh team	31 Oct 2026 (overdue)	Accepted Delay accepted by Board Risk Committee, 12 Oct 2026
TM alerts closed within SLA Head of Financial Crime Compliance	AMBER	**86%**	95%	80%	L1 and L2 queues are running above planned capacity. Action: Rebalance L1 and L2 queues	26 Feb 2027	Accepted Accepted by Executive Risk Committee, 20 Oct 2026

What has not changed

Standing position	Days	Next target	Committee
Fraud & Financial Crime — AMBER for 7 cycles. No evidence artefact on record. Remediation is in flight.	189	31 Oct 2026 **Overdue**	Delay accepted by Board Risk Committee, 12 Oct 2026
Banking Proposition Board approved this risk for 90 days. That was 160 days ago.	160	31 Oct 2026 **Overdue**	Delay accepted by Board Risk Committee, 12 Oct 2026
Cyber & Information Security — RED for 3 cycles. Last evidence 8 days ago. Remediation is in flight.	66	13 Nov 2026	Accepted by Board Risk Committee, 12 Oct 2026

3. Controls and incidents

94% of critical controls are effective, against 96% in the previous period.

Principal risk	This period	Previous	Critical controls effective
Fraud & Financial Crime	85%	90%	
Cyber & Information Security	90%	90%	
Climate Risk	100%	100%	
Conduct & Reputation	100%	100%	
Credit Risk	100%	100%	
Liquidity & Funding	100%	100%	
Market Risk	100%	100%	
Operational Resilience	100%	100%	
Regulatory	100%	100%	

Month-on-month movement

- AML-C002 retested 3 Nov 2026: not effective. Disposition control under capacity stress.

Sev-1 and Sev-2 incidents

Date	Severity	Incident	Category	Status	Linked controls
4 Nov 2026	**Sev-1**	Exploit attempt on unpatched perimeter vulnerability	Cyber & Information Security	Open	CY-C001: failed, CY-C006: worked
4 Nov 2026	**Sev-2**	Cross-border structuring alerts past disposition SLA	Fraud & Financial Crime	Open	AML-C002: failed
22 Oct 2026	**Sev-2**	Privileged account activity outside approved change window	Cyber & Information Security	Open	CY-C004: partial

Testing and evidence

- 1 green domain has no test evidence this cycle.
- Consumer Duty: GREEN with 0 evidence artefacts this cycle.
- Test overdue: MK-C004 IRRBB Stress Testing, Market Risk, due 12 Sep 2026.
- Test overdue: CL-C003 Climate Scenario Pathway Refresh, Climate Risk, due 12 Sep 2026.
- RCSA: 8 obligations have coverage gaps, 3 with no mapped control (DISP 1.6, PRIN 12, SS1/23), tracked in RCSA Coverage. Mapping refreshed on the RCSA cycle · last: 30 Jun 2026 · next: 31 Dec 2026.

4. Horizon scanning and emerging risks

Regulatory

Item	Source	Date	Why it matters
Precedent Match	Rule-based detection	5 Nov 2026	The FCA fined Nationwide Building Society £44,078,500 (from £62,969,297) on 2025-12-11 for the mechanism behind AML.01.05.02, which is RED on this pack.
Breach Without a Plan	Rule-based detection	5 Nov 2026	Fraud & Financial Crime has 4 KRI(s) outside appetite (worst: KYC Periodic Review Backlog at 4,210 (appetite 1,000)) while remediation step "Remediate medium / low-risk backlog" is Delayed.
Signed, Not Evidenced	Rule-based detection	5 Nov 2026	Cyber & Information Security has 2 remediation step(s) signed Complete with no linked test artefact, while the programme is 35% complete and the domain remains RED.
Standing Status	Rule-based detection	5 Nov 2026	Cyber & Information Security has been RED for 3 consecutive board cycles. Trend: stable. Delta: 0.
Barclays Bank PLC	FCA	14 Jul 2025	479 days not assessed. Reviewed exposure only after a peer was prosecuted
Nationwide Building Society	FCA	11 Dec 2025	329 days not assessed. "Enhanced" CDD reached 4.9% of the book
Bank of Ireland (UK) plc	PSR	19 Feb 2026	Only pre-deadline signal was a project RAG status
Monzo Bank Limited	FCA	7 Jul 2025	Breached its own requested restriction for 22 months

Industry events

Item	Source	Date	Why it matters	Relevant to us?
Google Cloud London region outage disrupts banks	Reuters, 21 Oct 2026	20 Oct 2026	A power event at a third-party facility took europe-west2 down for several hours; Revolut, Lloyds and HSBC were reported affected, and the EBA and FCA engaged Google.	Not assessed
Lloyds Banking Group app defect exposes transaction data	The Register, 27 Mar 2026	12 Mar 2026	An overnight IT change let up to 447,936 Lloyds, Halifax and Bank of Scotland customers see other customers' transaction lists; the Treasury Committee sought answers.	Not assessed

Emerging risks

Item	Source	Date	Why it matters
Post-quantum cryptography migration	NCSC, Mar 2025	20 Mar 2025	NCSC milestones: discovery and a migration plan by 2028, priority migration by 2031, full migration by 2035.
AI deepfake impersonation in investment scams	Cyber Daily, 10 Jun 2026	10 Jun 2026	The Bank of England warned that fake adverts impersonating central banks are on the rise, including AI deepfakes of its Governor.

Basis of ratings. Red if any metric is red, critical-control effectiveness is below 85% or a Sev-1 incident is open. Amber if any metric is amber, effectiveness is below 95% or a Sev-2 incident is open. Otherwise green. Ratings are calculated by rule from risk appetite metrics, control test results and incidents. Identifiers in square brackets refer to the underlying records. Next review: December 2026.